UNIT 2 · TOPIC 2.2

Physical Vulnerabilities and Attacks

Quiz, Answer Key

Teacher answer key, 18 questions, 1 point each. The correct answer is highlighted; the explanation and distractor notes follow.

1. Which of the following is classified as a physical attack on an organization's assets?

○ A. An attacker exploits a SQL injection flaw in a web login form to extract a database.

● B. An unauthorized person follows a badged employee through a secured entrance without scanning their own credential.

○ C. An attacker sends a phishing email impersonating the IT help desk to capture employee passwords.

○ D. An attacker uses a brute-force script to guess a wireless router password from a parking lot.

Correct answer: B

Why: Tailgating is a physical attack in which an unauthorized individual gains entry to a restricted area by closely following an authorized employee, bypassing physical access controls. SQL injection (A), phishing (C), and Wi-Fi brute-force (D) are all digital or network attacks that do not require physical premises access.

*Why the others are wrong: **A**, Students familiar with common attack types may apply "attack" broadly; SQL injection is a logical software attack, not a physical one. **C**, Phishing is a digital social engineering attack; students may confuse social engineering broadly with physical attacks. **D**, Wireless brute-force attacks operate at the network layer, not the physical premises layer, even when conducted from a nearby location.*

2. Which of the following scenarios describes an environmental threat to physical security?

○ A. An unauthorized visitor tailgates a researcher through a secured lab door.

○ B. A visitor photographs a sensitive document displayed on an unattended monitor.

○ C. An employee leaves a workstation unlocked and unattended when stepping away for lunch.

● D. A burst water pipe floods a ground-floor server room, destroying several rack-mounted servers.

Correct answer: D

Why: Environmental threats are naturally occurring or infrastructure-related events, floods, fires, power failures, extreme temperatures, that can damage or destroy physical assets without any deliberate human action. Tailgating (A), unattended workstations (C), and visual data theft (B) are human-initiated physical threats, not environmental ones.

*Why the others are wrong: **A**, Tailgating is a human-initiated physical attack; students may conflate "physical threat" with "environmental threat." **B**, Photographing a document is a human social-engineering or insider threat action, not an environmental one. **C**, An unlocked workstation is a procedural or policy vulnerability, not an environmental event.*

3. An attacker retrieves a discarded employee ID card and printed access-control policy from a recycling bin placed outside an office building. Which type of physical attack does this represent?

● A. Dumpster diving

○ B. Shoulder surfing

○ C. Tailgating

○ D. Device theft

Correct answer: A

Why: Dumpster diving is a physical attack in which an attacker searches discarded materials, printed documents, access cards, hard drives, device packaging, for information that can be used to compromise security. The attacker here is working alone with discarded items, not physically following anyone (C), watching anyone in real time (B), or stealing computing equipment (D).

*Why the others are wrong: **B**, Shoulder surfing requires real-time visual observation of a person entering credentials or viewing sensitive data. **C**, Tailgating requires physically following an authorized person through an access-controlled point; this attacker acted alone with*

discarded material. ***D****, Device theft involves stealing functioning computing equipment; recovering discarded paper or cards from a bin is not device theft.*

4. A physical security assessor at a newly acquired research lab identifies two vulnerabilities: (1) the building's main entrance has no lock and anyone can walk in, and (2) the server room has no cable locks on workstations. In terms of risk impact to data confidentiality, which vulnerability poses the greater threat and why?

○ A. Neither poses a significant risk to data confidentiality if all workstations are protected by login passwords.

○ B. The missing cable locks, because workstations can be physically removed from the premises with the data still on them.

○ C. Both pose an equal risk because each allows unauthorized access to physical assets.

● D. The unlocked entrance, because it enables a threat actor to physically reach any asset in the building, including the server room.

Correct answer: D

Why: The unlocked entrance is higher impact because it is a gateway vulnerability: gaining building access exposes all downstream assets, including the server room, unattended workstations, printed materials, and removable media. Missing cable locks (B) only expose devices in that specific room. Password protection (A) does not prevent physical attacks such as cold boot attacks, hardware extraction, or simply walking out with a device.

Why the others are wrong: ***A****, A common misconception: software-layer authentication does not protect against physical asset extraction or on-site tampering.* ***B****, Cable locks prevent device removal but don't address the deeper issue of unrestricted physical access to the entire facility.* ***C****, Equal risk requires equal scope of exposure; the entrance vulnerability exposes far more assets than missing cable locks on specific workstations.*

5. A server room at Xtensr Labs is located adjacent to a public corridor and has no environmental sensors installed. A water pipe in the adjacent corridor bursts, flooding the server room before staff are aware of the issue. Which factor best explains how a physical vulnerability enabled the environmental threat to cause destruction?

○ A. Lack of network segmentation allowed the flooding to cascade across interconnected systems.

○ B. The threat actor used social engineering to locate and burst the pipe at a strategic moment.

○ C. Encrypting the servers would have prevented the flood from causing data loss.

● D. The absence of environmental monitoring meant the flooding was not detected in time to prevent hardware destruction.

Correct answer: D

Why: The physical vulnerability here is the absence of environmental sensors (water detectors). Without early detection, the environmental threat (flooding) caused damage that timely intervention could have prevented. Network segmentation (A) is a logical control unrelated to physical flooding. Encryption (C) protects data confidentiality, not hardware integrity, it cannot prevent water damage. No human attacker is described in the scenario (B).

Why the others are wrong: ***A****, Network segmentation is a network-layer control; it has no bearing on physical water damage to hardware.* ***B****, Introduces an attacker where none exists; the scenario describes a purely environmental event and a monitoring failure.* ***C****, A recurring misconception: encryption secures data in a logical sense but does not prevent the physical destruction of the media on which data is stored.*

6. An attacker uses shoulder surfing to observe a system administrator typing credentials into a privileged management console in a shared open-plan office. Evaluate which asset category is most directly placed at risk by this attack.

● A. Privileged logical access to any system or data reachable by that administrator's account.

○ B. Encrypted backup tapes stored in an off-site vault.

○ C. Physical hardware in the server room managed by that console.

○ D. Network bandwidth and availability on the internal LAN.

Correct answer: A

Why: Shoulder surfing captures credentials. The direct impact is that the attacker obtains the same privileged access as the administrator, which may include servers, databases, user accounts, and configuration systems. Physical hardware (C) and off-site backups (B) are not directly threatened by credential capture alone, further access steps would be needed. Network bandwidth (D) is unrelated to credential theft.

*Why the others are wrong: **B**, Off-site encrypted backups require separate physical and logical access; captured console credentials do not automatically compromise them. **C**, Students may link "physical attack" to physical hardware risk; the immediate impact of shoulder surfing is on logical access, not physical hardware directly. **D**, Network bandwidth and availability are not affected by the theft of admin credentials through visual observation.*

7. A physical security analyst conducting the Xtensr Labs assessment identifies two vulnerabilities: (1) the server room has no badge reader, rated Likelihood: High, Impact: High; and (2) external windows in the server room are unbarred, rated Likelihood: Low, Impact: High. Using a standard likelihood-impact risk matrix, which vulnerability should be prioritized for remediation and on what basis?

○ A. Vulnerability 2, because high impact always takes precedence over likelihood in security risk evaluations.

○ B. Vulnerability 2, because physical barriers such as window bars are more difficult and costly to implement than badge readers, making them higher priority.

○ C. Both should be treated as equal priority because both carry a High impact rating.

● D. Vulnerability 1, because it occupies the highest risk tier on the matrix, both likelihood and impact are high, yielding a Critical composite score.

Correct answer: D

Why: In a standard likelihood × impact risk matrix, Vulnerability 1 (High × High = Critical) ranks higher than Vulnerability 2 (Low × High = High or Medium-High, depending on the scale). Prioritizing by impact alone (A, C) ignores the probability dimension, which is a fundamental error in risk evaluation. Implementation difficulty (B) is a mitigation planning consideration, not a risk scoring criterion.

*Why the others are wrong: **A**, Impact-only prioritization is a common oversimplification; risk frameworks require both dimensions to determine priority. **B**, Cost and implementation difficulty belong in the risk treatment phase, not the risk evaluation and prioritization phase. **C**, Equal impact ratings do not produce equal risk scores when likelihood differs; two-axis evaluation is the standard approach.*

8. An analyst evaluates the risk of device theft in a lab where researchers routinely leave laptops unattended and unlocked. She rates the likelihood as High. Because all research data is backed up daily to an off-site server, she rates the impact as Medium. Which conclusion best reflects proper composite risk impact evaluation?

● A. The risk is Medium-High, because a High likelihood combined with a Medium impact produces a mid-tier composite score, and residual impacts such as device replacement cost and brief data unavailability remain.

○ B. The risk is Low because daily backups effectively reduce the overall impact to near zero.

○ C. The risk is Critical because device theft would expose sensitive research data regardless of backups.

○ D. The risk is High because likelihood alone is the primary driver of risk score when impact cannot be fully quantified.

Correct answer: A

Why: Composite risk = likelihood × impact. High × Medium = Medium-High on most standard matrices. Backups lower impact but do not eliminate it: the physical device must be replaced, there may be downtime, and the thief may access unencrypted data in RAM or local cache before backups capture it. "Critical" (C) requires High × High. Backups don't reduce risk to Low (B) because likelihood is unchanged and residual impacts persist. Likelihood alone (D) is never sufficient to determine risk level.

*Why the others are wrong: **B**, Backups address one dimension of impact (data recovery) but do not affect likelihood or other impact dimensions such as device cost and potential local data exposure. **C**, Critical requires both high likelihood and high impact; Medium impact prevents Critical classification even at High likelihood. **D**, Risk scoring frameworks always require both likelihood and impact; using likelihood alone produces unreliable prioritization.*

9. A physical security team uses an AI-assisted tool to evaluate risk likelihood scores for the newly acquired Xtensr Labs building. The tool flags an unmonitored loading dock as "Low likelihood" based on historical incident logs from the previous occupant. As the lead analyst, which factor most critically limits the reliability of this AI-generated likelihood score?

○ A. AI risk evaluation tools cannot reliably process historical incident datasets larger than a few hundred records.

○ B. Loading docks are universally low-risk entry points in physical security frameworks, so the AI classification is likely accurate.

○ C. Likelihood scores must always be determined manually; AI tools have no valid role in physical security risk analysis.

● D. The historical data reflects the prior organization's threat environment and operational context, which may not apply to Xtensr Labs' different profile and threat actors.

Correct answer: D

Why: AI-assisted tools generate outputs based on the data they are trained on or seeded with. When that data reflects a prior organization's incident history, the resulting scores embed assumptions about threat actors, staff behavior, and environmental conditions that may not transfer to a new organization with a different profile, neighborhood, or value of assets. An analyst must validate AI-generated scores against the new site's evidence. (A) is factually incorrect, AI tools handle large datasets effectively. (C) is incorrect, AI has a legitimate role in risk analysis as an augmentation tool. (B) is incorrect, loading docks are commonly flagged as high-risk entry points in physical security frameworks precisely because they are often unsupervised.

*Why the others are wrong: **A**, A misconception about AI capability; dataset size is not the limiting factor here, data relevance and context-transfer are. **B**, Loading docks are standard high-risk physical entry points (large, often unmanned, vehicle-accessible); accepting a "Low" AI score without scrutiny is the error being tested. **C**, An overcorrection; AI tools are valid analytical aids in physical security risk analysis when outputs are validated by human analysts.*

10. Which of the following fields is always included in a risk register entry for a physical vulnerability?

○ A. The name of the hardware vendor whose equipment is affected.

● B. A description of the vulnerability, its likelihood of exploitation, and its potential impact.

○ C. The complete source code of any software associated with the vulnerability.

○ D. A full list of all employees who regularly use the affected physical space.

Correct answer: B

Why: A risk register entry must at minimum contain a description of the vulnerability, a likelihood rating (how probable the exploit is), and an impact rating (what harm would result). These three elements are required in every standard risk documentation framework. Vendor names (A) belong in asset inventories, source code (C) is relevant to software security assessments, and employee lists (D) belong in access control records.

*Why the others are wrong: **A**, Vendor information is tracked in asset or supply-chain records, not in risk register entries about physical vulnerabilities. **C**, Source code is relevant to application vulnerability assessments; physical risk register entries contain narrative and rating fields, not code. **D**, Employee access lists are part of access control management, not physical vulnerability risk documentation.*

11. A security analyst is documenting physical attacks observed at Xtensr Labs. A staff member reports that a visitor stood directly behind her at a shared kiosk and watched her enter her PIN. Which attack is the analyst documenting?

● A. Shoulder surfing

○ B. Tailgating

○ C. Piggybacking

○ D. Dumpster diving

Correct answer: A

Why: Shoulder surfing is the act of directly and visually observing another person's screen, keyboard, or keypad to capture sensitive input such as PINs, passwords, or confidential data. Tailgating and piggybacking (A, C) both involve physically following an authorized person through an access-controlled entry point. Dumpster diving (D) involves searching discarded materials for information.

*Why the others are wrong: **B**, Tailgating involves unauthorized physical entry through a secured door, not visual observation of credential entry. **C**, Piggybacking is synonymous with tailgating; it refers to physical co-passage through an access point, not visual credential theft. **D**, Dumpster diving requires searching discarded physical materials; this incident involves real-time visual observation.*

12. Which of the following most accurately describes the physical attack an analyst would label as dumpster diving when writing an incident report?

○ A. An attacker cuts through a server room wall to gain access without triggering door-based alarms.

● B. An attacker searches discarded materials, printed documents, decommissioned hard drives, or access badges, for information useful in compromising security.

○ C. An attacker gains entry to a restricted floor by following an authorized employee through a badge-controlled door.

○ D. An attacker installs a hardware keylogger on a workstation while posing as a maintenance worker.

Correct answer: B

Why: Dumpster diving exploits inadequate disposal procedures by recovering sensitive information from discarded materials. Organizations that shred documents, degauss drives, and physically destroy decommissioned access cards mitigate this attack. Cutting through walls (A) is a forced entry attack. Following through a badge door (C) is tailgating. Installing a hardware keylogger (D) is a device-based physical attack distinct from dumpster diving.

*Why the others are wrong: **A**, Forced-entry attacks involve breaking through physical barriers, not searching trash; the two attack categories are distinct in documentation. **C**, Tailgating is the correct term for following through badge-controlled access points; dumpster diving requires no personnel interaction. **D**, Hardware keylogging is a device tampering attack; it requires access to a specific machine, not a waste container.*

13. A security team at Xtensr Labs is documenting the risk posed by a server room with no door lock, located directly off a public corridor. Which field in a standard risk register entry specifically captures the mechanism by which this vulnerability can lead to data loss or disruption?

○ A. Asset value

● B. Threat description

○ C. Risk owner

○ D. Control status

Correct answer: B

Why: The threat description field explains how a specific threat actor can exploit a vulnerability to cause harm, in this case, how an unauthorized individual walking into the unlocked server room can cause data theft, hardware damage, or service disruption. Asset value (A) records what is at risk, not the mechanism of exploitation. Risk owner (C) assigns accountability. Control status (D) records existing or planned mitigations.

*Why the others are wrong: **A**, Asset value quantifies what is at stake; it does not describe the pathway from vulnerability to harm. **C**, Risk ownership is an administrative field identifying who is responsible for the risk; it does not explain how exploitation occurs. **D**, Control status describes whether mitigating controls exist or are planned, not the threat mechanism itself.*

14. When documenting the risk of unauthorized tailgating into a secured research lab, which asset category is most directly placed at risk according to the threat pathway described?

○ A. Software licenses and cloud subscriptions managed by the organization.

○ B. Employee payroll records stored in a third-party cloud HR platform.

○ C. Firewall access control list configurations stored on network appliances.

● D. Physical assets such as servers, workstations, removable media, and printed documents within the lab.

Correct answer: D

Why: Tailgating grants an attacker physical presence inside the facility, which directly threatens physical assets, hardware, removable media, and printed materials that can be stolen, damaged, or tampered with on-site. Logical/cloud assets (A, C, D) require separate authenticated access beyond mere physical presence; while an attacker who then uses an unattended workstation might reach them, the direct and immediate threat from tailgating falls on physical assets.

*Why the others are wrong: **A**, Software licenses and cloud subscriptions are accessed via authenticated network credentials, not by walking into a room. **B**, Cloud-hosted HR data requires authenticated remote access; tailgating into a physical space does not directly compromise it. **C**, Firewall ACL configurations require administrative system access; physical presence alone does not expose them.*

15. A security analyst is completing a risk register entry documenting the threat that power surges from ageing building infrastructure could destroy research workstations at Xtensr Labs. Which field in the entry specifically captures how probable this event is to occur within a defined timeframe?

○ A. Impact rating

● B. Likelihood rating

○ C. Residual risk

○ D. Risk treatment

Correct answer: B

Why: The likelihood rating (also called probability or frequency) captures how probable the threat event is to materialize within a defined period. Impact rating (A) quantifies the severity of consequences if the event occurs. Residual risk (C) is the remaining risk level after controls are applied, it cannot be calculated before likelihood is established. Risk treatment (D) describes the chosen response strategy (mitigate, accept, transfer, avoid) and is selected after risk evaluation is complete.

*Why the others are wrong: **A**, Impact and likelihood are two separate required fields; confusing them is one of the most common errors in risk register completion. **C**, Residual risk is a derived output calculated after control effectiveness is applied to the raw risk rating; it does not capture base probability. **D**, Risk treatment describes the planned or chosen response to an evaluated risk; it is filled in after, not instead of, likelihood and impact ratings.*

16. After completing the physical vulnerability assessment at Xtensr Labs, the security team presents findings to leadership. Leadership acknowledges an unmonitored loading dock as a documented vulnerability but formally decides, due to budget constraints, not to install a badge reader or camera. Which risk register field must be updated to correctly reflect this decision and maintain an auditable record?

○ A. Vulnerability description, to note that leadership reviewed it.

○ B. Likelihood rating, to lower it now that leadership has acknowledged the risk.

● C. Risk treatment decision, with the chosen response (risk acceptance) and a record of formal leadership sign-off and rationale.

○ D. Asset value, to reflect the reduced priority leadership has assigned to the affected area.

Correct answer: C

Why: When an organization formally decides to accept a risk rather than mitigate, transfer, or avoid it, the risk register's treatment decision field must be updated to record: the chosen response (acceptance), the rationale, the date, and the authorizing party's sign-off. This creates an auditable trail required by most governance and compliance frameworks. The vulnerability itself (A), the objective likelihood rating (B), and the asset value (D) do not change as a result of a management decision about how to respond to the risk.

*Why the others are wrong: **A**, The vulnerability description documents what the vulnerability is; it is not the correct field for recording treatment decisions or leadership sign-off. **B**, Leadership acknowledgment does not change the objective probability of a threat occurring; likelihood is a factual assessment, not a management preference. **D**, Asset value is an objective measure of asset worth; it is not altered by a policy or budget decision about risk treatment.*

17. A security professional uses an AI-assisted tool to auto-populate a risk register for physical vulnerabilities at the newly acquired Xtensr Labs facility. The tool generates entries for tailgating, dumpster diving, and device

theft, but assigns identical likelihood scores (Medium) to all three threats. What is the most important action the analyst must take before submitting the report to leadership?

○ A. Replace all AI-generated entries with manually written descriptions to comply with physical security documentation standards.

○ B. Accept the AI-generated scores without modification, because AI tools are trained on large industry datasets and produce more reliable scores than individual analyst judgment.

● C. Validate and, where necessary, adjust each AI-generated likelihood score using site-specific evidence such as access logs, physical inspection notes, and incident history from comparable facilities.

○ D. Submit the report with a disclosure statement noting that AI was used, which satisfies the organization's audit and compliance requirements.

Correct answer: C

Why: AI-assisted tools generate outputs based on generalized training data or prior datasets, which may not reflect the specific threat environment, physical layout, or operational context of the new facility. Identical likelihood scores for structurally different physical attack types are a signal of generalized, context-free output. The analyst's professional obligation is to validate each score against observable, site-specific evidence before the report is finalized. Full manual replacement (A) discards the efficiency value of AI tooling. Uncritical acceptance (B) abdicates analyst judgment and responsibility. Disclosure alone (D) does not compensate for inaccurate data in the submitted report.

*Why the others are wrong: **A**, Replacing all AI content is unnecessarily inefficient and defeats the purpose of AI-assisted documentation; the correct action is validation and selective correction, not wholesale replacement. **B**, Blind acceptance of AI outputs without analyst validation is a well-documented failure mode; AI tools augment but do not replace professional judgment in risk documentation. **D**, Disclosure is good practice, but it does not satisfy audit requirements if the underlying data is inaccurate; accuracy of the risk register is the analyst's responsibility regardless of what tool generated it.*

18. During the Xtensr Labs physical vulnerability assessment, an analyst documents two risks in the register: Risk A, a prop door in a secure corridor (Likelihood: High, Impact: Low); Risk B, proximity of the server room to an external wall with no blast or intrusion protection (Likelihood: Low, Impact: High). When recommending risk response priorities in the documentation, which principle should guide the ordering?

○ A. Risk B should always be prioritized because catastrophic but infrequent events pose inherently greater danger than frequent low-impact events.

● B. Both risks should be evaluated using a composite risk score (likelihood × impact), and their treatment order should be determined by that score in conjunction with the organization's documented risk appetite and tolerance thresholds.

○ C. Risk A should be prioritized because frequent low-impact events can accumulate over time and cause aggregate harm greater than a single high-impact event.

○ D. Neither risk requires prioritized documentation since neither simultaneously exhibits high likelihood and high impact.

Correct answer: B

Why: Standard risk frameworks (NIST SP 800-30, ISO 27005) require composite risk scoring and explicit reference to the organization's risk appetite and tolerance before treatment priorities can be assigned. Risk A (High × Low) and Risk B (Low × High) may yield similar composite scores, making risk appetite the deciding factor, some organizations are more averse to rare catastrophic events, others to frequent disruptive ones. Automatically prioritizing impact (A) or frequency (C) ignores the other dimension. Deferring both (D) is incorrect: Medium-tier risks still require documented treatment decisions under governance and compliance frameworks.

*Why the others are wrong: **A**, Impact-first prioritization is a legitimate organizational policy in some contexts, but it is not a universal principle, it must be grounded in documented risk appetite, not assumed. **C**, Cumulative harm from frequent low-impact events is a valid actuarial concept but is not the standard risk prioritization criterion in NIST or ISO-aligned cybersecurity risk documentation frameworks. **D**, Medium-tier risks absolutely require documentation and a formal treatment decision; only risks assessed as negligible or below the organization's risk threshold may be accepted without active response planning.*